different requirements relating to service providers;[692] and the extension of the rule's scope to include all transfer agents.[693] As discussed below, we have also made changes to the final amendments that will reduce compliance costs for all covered institutions, including those that are smaller in size.[694]

Several commenters stated that the Commission should consider the cumulative costs of implementing the proposed amendments and other recent Commission rules and proposed rules.[695] Specifically, one commenter stated that "there can be no doubt that the costs of compliance—direct and indirect—rise with each regulation and directly impact the ability of [covered institutions] to invest in other aspects of their businesses" and that the Commission should "consider the cumulative effects that" the final amendments and other adopted rules will have on covered institutions' "operational limitations and, more importantly, resource constraints, in determining the compliance dates."[696] That commenter and others mentioned proposals which culminated in several adopted rules.[697]

Consistent with its long-standing practice, the Commission's economic analysis in each adopting release considers the incremental benefits and costs for the specific rule—that is, the benefits and costs stemming from that rule compared to the baseline. The Commission acknowledges the possibility that complying with more than one rule may entail costs that could exceed the costs if the rules were to be complied with separately. Four of the rules identified by commenters have compliance dates that occur before the effective date of the final

---

692 *See infra* section IV.D.1.c; *see also supra* sections IV.C.2.a(3) and IV.C.3.f.

693 *See infra* section IV.D.1.b; *see also supra* section IV.C.2.a(3).

694 *See infra* footnote 1058 and accompanying text.

695 *See supra* footnote 482.

696 *See* IAA Comment letter 2.

697 *See supra* footnotes 483-493.

amendments,[698] such that there is no overlap in compliance periods. The compliance periods for the other rules overlap in part, but the compliance dates adopted by the Commission in recent rules are generally spread out over an approximately three-year period from 2023 to 2026,[699] which could limit the number of implementation activities occurring simultaneously. Where overlap in compliance periods exists, the Commission acknowledges that there may be additional costs on those covered institutions subject to one or more other rules as well as implications of those costs, such as impacts on entities' ability to invest in other aspects of their businesses.[700]

Covered institutions subject to the final amendments in this rulemaking may be subject to one or more of the other adopted rules commenters named depending on whether those institutions' activities fall within the scope of the other rules. Specifically, the rules and amendments in the February 2024 Form PF Adopting Release, and those rules and amendments in the Private Fund Advisers Adopting Release for which the compliance dates have not already passed, apply to advisers to private funds: as private fund advisers are a subset of the covered institutions affected by the amendments, only a subset of covered institutions face compliance costs associated with these recent rules and amendments.[701] The Public Company Cybersecurity Rules apply only to public companies, not all covered institutions.[702] The amendments adopted in

---

698 The compliance dates for the Electronic Recordkeeping Adopting Release occurred in 2023, and the compliance date for the Settlement Cycle Adopting Release is May 28, 2024. The compliance dates for the May 2023 SEC Form PF Adopting Release and the Form N-PX Adopting Release are June 11, 2024, and July 1, 2024, respectively.

699 *See supra* section IV.C. In addition, we adopted longer compliance periods for all covered institutions relative to the proposal, and an even longer compliance period for smaller covered institutions. *See supra* section II.F.

700 *See*, *e.g.*, IAA Comment letter 2 (describing the types of implementation activities, such as updating internal controls, and training).

701 *See* Private Fund Advisers Adopting Release, at section VI.C.1; February 2024 Form PF Adopting Release, at section IV.B.2.

702 *See* Public Company Cybersecurity Rules, at section IV.B.2. One commenter also suggested the Commission should consider the relationship between reporting obligations in the proposed amendments

the Money Market Fund Adopting Release place a compliance burden on money market funds and certain liquidity fund advisers registered with the Commission, which are also a subset of covered institutions.[703] The Investment Company Names Adopting Release amended requirements for those registered investment companies and BDCs with names with terms suggesting that the fund has particular characteristics, which are a subset of the funds affected by the final amendments.[704] The Beneficial Ownership Adopting Release amended disclosure requirements that apply only to persons who beneficially own more than five percent of a covered class of equity securities.[705] The rule adopted in the Securitization Conflicts Adopting Release affects only certain entities (and their affiliates and subsidiaries) that participate in securitization transactions.[706] We acknowledge that covered institutions subject to multiple rules may still experience increased costs associated with implementing multiple rules at once as well as implications of those costs, such as impacts on those institutions' ability to invest in other aspects of their businesses.

1. Written Policies and Procedures

In this section, we discuss the effects of written policies and procedures requirements in the final amendments, focusing on those relating to the incident response program required under the final amendments. Specifically, while the final amendments require covered institutions to develop, implement, and maintain written policies and procedures that address administrative,

---

and the Public Company Cybersecurity Rules. *See* ASA Comment Letter. We modified the final amendments, relative to the proposal, to align with the Public Company Cybersecurity Rules with regard to disclosure delays for national security or public safety reasons. *See supra* section II.A.(d)(2).

703 *See* Money Market Fund Adopting Release, at section IV.B.

704 *See* Investment Company Names Adopting Release, at section IV.C.

705 *See* Beneficial Ownership Adopting Release, at section IV.B.3.

706 *See* Securitization Conflicts Adopting Release, at section IV.B.2.

technical, and physical safeguards for the protection of customer information,[707] general written policies and procedures to protect customer information are already part of the baseline.[708] The primary new requirements pertain to written policies and procedures that must include an incident response program to address unauthorized access to or use of customer information.

We expect that requiring written policies and procedures for the response program will improve the effectiveness of response programs in multiple ways, which will benefit covered institutions and their customers. Written policies and procedures are a practical prerequisite for organizations to implement standard operating procedures and have been recognized as effective at improving outcomes in critical environments.[709] We expect that this will also be the case for response programs for data breach incidents. Written policies and procedures can help ensure that the covered institution's personnel know what corrective actions to take and when in the event of a data breach. Written policies and procedures can also help ensure that the incident is handled in an optimal manner. Moreover, establishing incident response procedures ex ante can facilitate discussion among the covered institution's staff and expose flaws in the incident response procedures before they are used in a real response. This may also lead to covered

---

707 *See* final rule 248.30(a)(1).

708 Prior to this adoption, Regulation S-P already required covered institutions to adopt policies and procedures reasonably designed to protect customer information. *See supra* section IV.C.2.b. Transfer agents were not previously covered by the safeguards rule and were not, before this adoption, required by the Commission to have such written policies and procedures in place. We analyze the benefits and costs that are specific to transfer agents in section IV.D.2.b.

709 Other Commission regulations, such as the Investment Company Act and Investment Advisers Act compliance rules, require policies and procedures. 17 CFR 270.38a-1(a)(1), 275.206(4)-7(a). The utility of written policies and procedures is recognized outside the financial sector as well; for example, standardized written procedures have been increasingly embraced in the field of medicine. *See, e.g.*, Robert L. Helmreich, *Error Management as Organizational Strategy*, *In Proceedings of the IATA Human Factors Seminar, Vol. 1*., Citeseer (1998); *see also* Joseph Alex, Chaparro Keebler, Elizabeth Lazzara & Anastasia Diamond, *Checklists: A Review of Their Origins, Benefits, and Current Uses as a Cognitive Aid in Medicine*, *Ergonomics in Design*, 2019 Q. HUM. FAC. APP. 27 (2019). We are not aware of any studies that assess the efficacy of written policies and procedures specifically in the context of financial regulation, and no commenter provided such sources.

institutions improving their customer information safeguards, which could reduce the likelihood of unauthorized access to or use of customer information in the first place.[710]

We do not anticipate that the final requirement for written policies and procedures will result in substantial new benefits from its application to large covered institutions, those with a national presence, or those already subject to comparable Federal regulations. As stated above,[711] all states and the District of Columbia generally require businesses to notify their customers when certain customer information is compromised. States do not typically require the adoption of written policies and procedures for the handling of such incidents.[712] However, despite the lack of explicit statutory requirements, covered institutions—especially those with a national presence—may have developed and implemented written policies and procedures for a response program that incorporates various standard elements, including for assessment, containment, and notification.[713] Given the numerous and distinct state data breach laws, it would be difficult for larger covered institutions operating in multiple states to comply effectively with existing state laws without having some written policies and procedures in place. As such covered institutions are generally larger, they are more likely to have compliance staff dedicated to designing and implementing regulatory policies and procedures, which could include policies and procedures regarding incident response. Moreover, to the extent that covered institutions that have already developed written policies and procedures for incident response have based such policies and

---

710 *See infra s*ection IV.D.1.b(3) for examples of how covered institutions could enhance their customer information safeguards.

711 *See supra* section IV.C.2.

712 Some states do, however, require businesses to have procedures to protect personal information. *See, e.g.*, Cal. Civil Code § 1798.81.5 and N.Y. Gen. Bus. Law. § 899-BB.

713 Various industry guidebooks, frameworks, and government recommendations share many common elements, including the ones included in the final amendments. *See, e.g.*, NIST Computer Security Incident Handling Guide and CISA Incident Response Playbook.

procedures on common cyber incident response frameworks (e.g., NIST Computer Security Incident Handling Guide, CISA Cybersecurity Incident Response Playbook),[714] generally accepted industry best practices, or other applicable regulatory guidelines,[715] these large covered institutions' written policies and procedures are likely to include the elements of assessment, containment, and notification, and to be substantially consistent with the requirements of the final amendments. Thus, we do not anticipate that the final requirement for written policies and procedures will result in substantial new benefits from its application to these institutions.

For the same reasons, this requirement is unlikely to impose significant new costs for these institutions. As discussed below, we estimate that certain costs associated with developing and implementing policies and procedures to comply with the final amendments will be, on average, $15,445 per year per covered institution.[716] Here, we expect the main costs associated with the final requirement to be the costs of reviewing, and possibly updating, existing policies and procedures to ensure that they satisfy the new requirements. Hence, we expect these reviews and updates will result in these covered institutions incurring direct compliance costs generally smaller than the costs of developing and implementing new policies and procedures. If covered institutions respond to this requirement by improving their customer information safeguards

---

714 *See supra* footnote 625.

715 For example, the Banking Agencies' Incident Response Guidance states that covered institutions that are subsidiaries of U.S. bank holdings companies should develop response programs that include assessment, containment, and notification elements. *See supra* discussion of Banking Agencies' Incident Response Guidance in text accompanying footnote 605.

716 This estimate is an annual average for the first three years. The corresponding ongoing annual costs beyond the first three years are estimated to be on average $5,425 per year per covered institution. *See infra* section V. We expect that for some institutions, the actual costs might be lower than these estimates. For example, there may be some portability between funds belonging to the same family of investment companies, which could mitigate costs per investment company. *See supra* section IV.C.3.d. We estimate that these costs will be higher for transfer agents because transfer agents were not, before this adoption, covered by the safeguards rule. In addition, transfer agents registered with a regulatory agency other than the Commission were not, before this adoption, covered by the disposal rule. *See infra* footnote 1003 and accompanying text.

beyond what is required by the final amendments, they will incur additional costs.[717] We expect that the costs incurred by these covered institutions as a result of this requirement will ultimately be passed on to customers of these institutions.[718]

We expect that the final written policies and procedures requirements will have more substantial benefits and costs for smaller covered institutions without a national presence, such as small registered investment advisers and broker-dealers who cater to a clientele based on geography, as compared to larger covered institutions. Before this adoption, some of these covered institutions may have had lower incentives to develop and implement written policies and procedures for a response program and may therefore have been less likely to have such policies and procedures in place for several reasons. First, the incentives to develop and implement policies and procedures for a response program may vary for covered institutions of different sizes. Some smaller covered institutions may already prioritize response programs, for example because the firm views reputational costs of a cybersecurity breach or other type of unauthorized access to or use of customer information as posing the potential for serious harm to the firm. However, for other smaller covered institutions, the firm and its managers may view response programs as lower priority because, for example, the potential reputational cost of an unauthorized access to or use of customer information may be relatively smaller than it would be for a larger firm. This would be the case to the extent that the firm and its managers perceive that the firm has a lower franchise value (the present value of the future profits that a firm is expected

---

717 Because covered institutions could decide to enhance their customer information safeguards in many different ways, we are unable to quantify expected costs resulting from such enhancements. *See infra* section IV.D.1.b(3) for examples of how covered institutions could enhance their customer information safeguards as a result of the final amendments.

718 Costs incurred by larger covered institutions as a result of the final amendments will generally be passed on to their customers in the form of higher fees. However, smaller covered institutions—which are likely to face higher costs relative to their size—may not be able to do so. *See infra* section IV.E.

to earn as a going concern) and lower brand equity (the value of potential customers' perceptions of the firm). Thus, the costs of potential reputational harm may be perceived to be lower than at larger firms. Moreover, the cost of developing and implementing written policies and procedures for a response program is proportionately large compared to larger covered institutions since it involves fixed costs.

Second, some covered institutions could potentially have, before this adoption, complied effectively with the relevant state data breach notification laws without adopting written policies and procedures to deal with customer notification: they may only have needed to consider—on an ad hoc basis—the notification requirements of the small number of states in which their customers reside.[719] Hence, for such covered institutions, the cost of developing policies and procedures will be relatively larger, but the benefits for the customers of these institutions will also be larger.

We expect that for such covered institutions, the final amendments will likely impose additional compliance costs related to written policies and procedures for safeguarding customer information.[720] Certain costs associated with developing and implementing policies and procedures to comply with the final amendments are estimated to be $15,445 generally per year per covered institution, but may vary depending on the size of the institution and the current state

---

[719] As discussed above, many registered investment advisers have clients in only a few states. *See supra* section IV.C.3.c.

[720] The existing policies and procedures were already required under Regulation S-P before this adoption; *see* 17 CFR 248.30. The final amendments may also generate additional costs to covered institutions who decide to improve their customer information safeguards to avoid the potential reputational harm associated with the customer notification requirements. However, one commenter stated that the FTC has often noted that reasonable security measures are a relatively low cost. *See* EPIC Comment Letter. Such improvements in customer information safeguards would also provide potential benefits to customers in addition to reducing the risk of reputational harm for the covered institutions.

of their existing policies and procedures.[721] Furthermore, as for larger covered institutions, if these covered institutions respond to this requirement by improving their customer information safeguards beyond what is required by the final amendments, they will incur additional costs. While these smaller covered institutions might potentially pass some of the costs resulting from the final amendments on to customers in the form of higher fees, their ability to do so may be limited due to the presence of larger competitors with more customers across which to spread costs.[722] In addition, covered institutions that improve their customer notification procedures in response to the final amendments might suffer reputational costs resulting from the additional notifications.[723]

Some commenters stated that many covered institutions already had policies and procedures in place.[724] These commenters also stated that these policies and procedures would need to be reviewed and updated to comply with the amendments, but to different extents. On the one hand, one commenter stated that its members already complied with much of the proposal's content through state regulations, such as the requirements that companies maintain written cybersecurity policies and procedures, respond to cyber incidents, notify authorities and

---

721 This estimate is an annual average for the first three years. The corresponding ongoing annual costs beyond the first three years are estimated to be on average $5,425 per year per covered institution. *See infra* section V. We expect that for some institutions, the actual costs might be lower than these estimates. For example, there may be some portability between funds belonging to the same family, which could mitigate costs. *See supra* section IV.C.3.d.

722 *See supra* section IV.C.3. Developing and implementing written policies and procedures for a response program involves fixed costs. Larger institutions can spread these costs over a larger number of customers, resulting in a smaller increase in the price that each customer pays. Smaller institutions must spread these costs over a smaller number of customers, resulting in a larger price increase per customer. This could result in smaller institutions losing more customers as a result of the increase in price. Hence, smaller institutions could decide to absorb more of the costs compared to large institutions in order to avoid losing customers.

723 *See supra* section IV.B; *see also infra* section IV.D.1.b.

724 *See, e.g.*, IAA Comment Letter 1; SIFMA Comment Letter 2.

consumers of certain cyber incidents, and dispose of consumer data.[725] A second commenter stated that the customer notification requirements would need to be incorporated into existing policies and procedures.[726] These commenters' perspectives are consistent with our view that the final rules will impose a fairly limited burden for covered institutions bringing existing policies and procedures into compliance with the new requirements. On the other hand, a different commenter stated that written incident response program policies and procedures and recordkeeping requirements would need to be created and implemented,[727] indicating higher potential burden. Hence, we continue to expect that the policies and procedures requirements will potentially have different effects on different covered institutions.[728] In a change from the proposal and after considering commenters' concerns, we are now adopting a longer compliance period for all covered institutions relative to the proposal, and an even longer compliance period of 24 months for smaller covered institutions, which are less likely to already have policies and procedures broadly consistent with the final amendments.[729]

Two commenters discussed how the proposed amendments would affect an entity that is dually registered as an investment adviser and broker-dealer. One commenter stated that it appreciated the approach of the proposal, which applies uniformly to the two types of covered institutions and would allow for streamlining of processes.[730] Another commenter stated that

---

725 *See* ACLI Comment Letter.

726 *See* SIFMA Comment Letter 2.

727 *See* IAA Comment Letter 1.

728 For example, some covered institutions, such as transfer agents, may not have existing notification procedures since they may not have been required, under state law, to notify customers in case of a breach. *See supra* section IV.C.2.a(3); *infra* section IV.D.2.b.

729 The compliance period for larger institutions under the final amendments is 18 months from the date of publication in the Federal Register. The proposed compliance period for all covered institutions was 12 months from the effective date of the final amendments. *See supra* section II.F.

730 *See* FSI Comment Letter.